

Vulnerability Assessment Report

Arkose Labs (arkoselabs.com)

Bug Bounty Program - Authorized Assessment

Assessment Date: June 15, 2026

Target: arkoselabs.com (subdomains: www, portal, developer, API)

Classification: CONFIDENTIAL

Assessment Type: External Web Application Security Review

Methodology: OWASP Web Security Testing Guide v4.2

Reporting Standard: CVSS 3.1

Program: Future Interns Penetration Testing Program

*This report is produced as part of an authorized security assessment.
All testing was conducted with explicit permission via the Bugcrowd bug bounty program.*

Table of Contents

- 1. Executive Summary**
- 2. Assessment Scope & Methodology**
- 3. Target Summary & Technology Stack**
- 4. Risk Summary**
- 5. Detailed Findings**
 - 5.1 Missing Security Headers
 - 5.2 Verify API Verbose Error Disclosure
 - 5.3 Stale DNS Records / Subdomain Takeover Risk
 - 5.4 Third-Party Supply Chain Dependency
 - 5.5 robots.txt Internal Path Disclosure
 - 5.6 Sitemap Reconnaissance Aid
- 6. Remediation Roadmap**
- 7. Appendix: Subdomain Inventory**

1. Executive Summary

Arkose Labs engaged (via bug bounty program) a security assessment of their public-facing web properties. The scope included the main website (www.arkoselabs.com), customer portal (portal.arkoselabs.com), developer portal (developer.arkoselabs.com), and supporting API infrastructure.

The assessment methodology combined passive reconnaissance (DNS enumeration via Certificate Transparency logs, subdomain discovery), active endpoint analysis (HTTP header inspection, API response analysis, and technology fingerprinting), and manual security review of web application configurations.

Overall, Arkose Labs demonstrates a mature security posture with: Cloudflare WAF protection, quarterly third-party penetration testing, annual red-team exercises, a published responsible disclosure program, SOC 2 Type II reporting, and ISO certifications. However, several areas for improvement were identified that could strengthen the defense-in-depth posture.

Key Findings at a Glance:

- Security headers (CSP, HSTS, X-Frame-Options) are not fully configured, leaving the site vulnerable to clickjacking, cross-site scripting, and MIME-type sniffing attacks. This is the highest-impact, lowest-cost finding to fix.
- The API verify endpoint returns verbose error messages that include timestamps and internal status details, helping attackers map the internal system architecture.
- Multiple DNS records exist for subdomains that no longer point to active hosting, creating a subdomain takeover risk if those cloud services have been de-provisioned.
- Static assets are exclusively hosted on a third-party CDN (Webflow) without Subresource Integrity (SRI) hashes, exposing the site to supply chain attacks if the CDN is compromised.

Bottom Line for Management:

Arkose Labs has a strong security foundation with established compliance programs, regular penetration testing, and a bug bounty program. The issues identified in this assessment are common across enterprise web properties and are straightforward to remediate. Prioritizing the security headers configuration (CSP, HSTS) will deliver the greatest risk reduction for minimal engineering effort.

2. Assessment Scope & Methodology

2.1 In-Scope Targets

- www.arkoselabs.com - Main marketing website
- portal.arkoselabs.com - Customer portal
- developer.arkoselabs.com - Developer documentation portal
- client-api.arkoselabs.com - Client-side API endpoint

- [verify.arkoselabs.com](#) - Session verification API
- [cdn.arkoselabs.com](#) - CDN distribution point
- [status.arkoselabs.com](#) - Status page

2.2 Methodology

- **Passive Reconnaissance:** DNS enumeration via Certificate Transparency logs (crt.sh), WHOIS lookups, DNS resolution analysis, and public record searching
- **Technology Fingerprinting:** Identifying web frameworks, CDN providers, CMS platforms, and third-party service integrations via HTTP headers, HTML meta analysis, and known signatures
- **Security Header Analysis:** Comprehensive review of HTTP security headers including CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Permissions-Policy, and Referrer-Policy
- **API Endpoint Testing:** Analysis of public API responses for information disclosure, error handling, and authentication mechanism exposure
- **Subdomain Discovery:** Systematic enumeration using crt.sh CT logs, DNS brute-force techniques, and CNAME resolution analysis

2.3 Risk Classification Standard

Findings are classified using CVSS v3.1 (Common Vulnerability Scoring System). Severity ratings correlate to CVSS score ranges: High (7.0-10.0), Medium (4.0-6.9), Low (0.1-3.9), and Informational (0.0). Risk ratings consider exploitability, impact to confidentiality/integrity/availability, and the maturity of the finding.

3. Target Summary & Technology Stack

3.1 Target Overview

Attribute	Value
Domain	arkoselabs.com
Registrar	Amazon Registrar, Inc.
DNS	AWS Route 53 (ns-1019.awsdns-63.net, ns-1457.awsdns-54.org, etc.)
CDN / WAF	Cloudflare
Primary Host	Webflow CMS (cdn.prod.website-files.com)
API Infrastructure	AWS CloudFront + EC2 multi-region
Cookie Mgmt	OneTrust
Status Page	Atlassian Statuspage
Auth Provider	Okta (sub-processor)
Country (Registrant)	United Kingdom
Bug Bounty	Bugcrowd (Private + Public)

Disclosure Email	security@arkoselabs.com
------------------	-------------------------

3.2 Global Infrastructure (Discovered via Status Page)

- North Virginia (us-east-1) - AWS
- Ohio (us-east-2) - AWS
- Oregon (us-west-2) - AWS
- Ireland (eu-west-1) - AWS
- Singapore (ap-southeast-1) - AWS
- Sydney (ap-southeast-2) - AWS

4. Risk Summary

A total of 6 findings were identified during this assessment. These are distributed across severity levels as shown in the table below. No critical vulnerabilities were identified that would allow immediate, unauthenticated remote compromise of the target.

Severity	Finding	CVSS	Count	Category
High	Missing Security Headers (CSP, HSTS, X-Frame-Options)	7.1	1	Configuration
Medium	Verify API Verbose Error Information Disclosure	4.3	1	Information Disclosu
Medium	Stale DNS Records / Subdomain Takeover Risk	5.0	1	Infrastructure
Low	Third-Party Supply Chain Dependency without SRI	3.7	1	Supply Chain
Low	robots.txt Internal Path Disclosure	2.1	1	Information Disclosu
Low	Sitemap Granular Reconnaissance Data	1.0	1	Information Disclosu
Total Findings			6	

Severity Distribution



5. Detailed Findings

[VA-001]**Missing Security Headers****High**

CVSS: 7.1 (AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:H/A:N) | Finding ID: VA-001

Description

The main website (www.arkoselabs.com) and associated subdomains were found to be missing critical security HTTP response headers. Specifically: Content-Security-Policy (CSP) was not implemented with a strict policy, X-Frame-Options was not set, Permissions-Policy was absent, and the HSTS header was not observed with a sufficiently long max-age directive including preload. The site loads multiple third-party scripts (Google Tag Manager, OneTrust, Facebook Pixel, Webflow CDN) without Subresource Integrity (SRI) hashes or strict CSP enforcement.

Technical Impact

Without X-Frame-Options or a CSP frame-ancestors directive, the site is susceptible to clickjacking attacks where an attacker could load the site in a transparent iframe and trick users into performing unintended actions. Without HSTS, users connecting over HTTP for the first time are vulnerable to SSL-stripping man-in-the-middle attacks. Without a strict CSP, any Cross-Site Scripting (XSS) vulnerability in the application or in third-party scripts could be exploited to exfiltrate data, perform actions as the user, or deploy malware.

Business Impact

These missing headers significantly increase the risk of client-side attacks against Arkose Labs website visitors. If exploited, attackers could steal login credentials from users accessing the customer portal, perform unauthorized actions in the user's session, or inject malicious content that damages trust in the Arkose Labs brand. For a cybersecurity company that sells fraud prevention solutions, these gaps in their own security posture could be seen as inconsistent with the product value proposition.

Remediation

Implement the following HTTP response headers on the origin server (or via Cloudflare Workers):

1. Content-Security-Policy:

default-src 'self'; script-src 'self' 'nonce-{random}' https://cdn.prod.website-files.com https://cdn.cookie law.org;
frame-ancestors 'none'; base-uri 'self'; form-action 'self'

2. Strict-Transport-Security:

max-age=31536000; includeSubDomains; preload

3. X-Frame-Options: DENY

4. X-Content-Type-Options: nosniff

5. Permissions-Policy:

camera=(), microphone=(), geolocation=(), payment=()

6. Referrer-Policy: strict-origin-when-cross-origin

Additionally, add Subresource Integrity (SRI) hashes to all third-party script tags.

[VA-002]

Verify API Verbose Error Information Disclosure

Medium

CVSS: 4.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N) | Finding ID: VA-002

Description

The verify endpoint (verify.arkoselabs.com/api/v4/verify/) returns structured JSON error responses that include an exact UTC timestamp and the internal verification status. The response body: {"error":"DENIED ACCESS","verified":"2026-06-15T10:51:37Z"}. While the error itself is generic, the inclusion of precise server timestamps and the "verified" field naming confirms API implementation details to potential attackers.

Technical Impact

Information disclosure aids attackers in mapping the API infrastructure. The timestamp reveals server timezone (UTC) and can be used for timing attacks or session replay analysis. Knowing exact error response structures helps attackers craft more sophisticated API abuse scripts and bypass attempts.

Business Impact

While this finding does not directly expose customer data or allow unauthorized access, it reduces the friction for attackers attempting to reverse-engineer the verification API. For a security vendor whose core product relies on API-based verification, minimizing information leakage is important for maintaining the difficulty of bypass attempts.

Remediation

- Return only generic error messages to unauthenticated API clients:
{"error": "invalid_request"}
- Log detailed error information server-side only with appropriate access controls
- Implement consistent error responses across all API versions
- Remove timestamps from error responses to public API endpoints
- Apply rate limiting to the verify endpoint to prevent automated probing

[VA-003]

Stale DNS Records / Subdomain Takeover Risk

Medium

CVSS: 5.0 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N) | Finding ID: VA-003

Description

Multiple DNS records for arkoselabs.com subdomains point to hosts that no longer serve active content. The subdomains cdn.arkoselabs.com and match-verify.arkoselabs.com return HTTP 404 errors. Several other subdomains discovered via Certificate Transparency logs (www-staging, www-production, test-cases-*) have DNS records but no responding hosts. If any of these subdomains use AWS services (CloudFront distributions, S3 buckets, Elastic Beanstalk) that have been deleted, an attacker could claim the same resource name and serve malicious content under the trusted arkoselabs.com domain.

Technical Impact

A successfully claimed subdomain could host phishing pages, malware downloads, or credential harvesting forms that appear to be legitimate Arkose Labs services. Since these would share the root domain, browser security policies would

trust cookies, localStorage, and other data shared with the main site. This could compromise customer credentials and trust in the Arkose Labs brand.

Business Impact

For a security company that protects enterprises from phishing and credential theft, having an abandoned subdomain hijacked for those exact purposes would cause significant reputational damage and undermine customer confidence. Brand trust takes years to build and minutes to destroy - DNS hygiene is a critical part of brand protection.

Remediation

1. Conduct a complete DNS audit for all resource records under arkoselabs.com
2. Remove DNS records for decommissioned services immediately
3. Implement a formal DNS lifecycle policy:
 - Record creation requires ticket/tracking
 - Record deletion occurs within 24 hours of resource deprovisioning
4. Subscribe to automated subdomain takeover detection services
5. Use CNAME validation before creating DNS entries for cloud services
6. Monitor certificate transparency logs for unauthorized certificate issuance

[VA-004]	Third-Party Supply Chain Dependency without SRI
Low	CVSS: 3.7 (AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N) Finding ID: VA-004

Description

The website loads 100% of its static assets (JavaScript, CSS, images) from external CDNs, primarily Webflow's cdn.prod.website-files.com, along with scripts from cdn.cookie law.org (OneTrust) and www.googletagmanager.com (Google Tag Manager). None of these external resources use Subresource Integrity (SRI) attributes to verify the cryptographic hash of the expected file contents.

Technical Impact

If any of the third-party CDN services are compromised (either through malicious attack or accidental misconfiguration), modified JavaScript could be served to all Arkose Labs visitors. This JS could steal login credentials, exfiltrate session cookies, mine cryptocurrency in browser tabs, or redirect users to phishing pages. Without SRI, there is no browser-level protection against these supply chain attacks.

Business Impact

A supply chain attack through compromised CDN scripts would affect every visitor to arkoselabs.com and portal.arkoselabs.com simultaneously. For a company selling security solutions, having their own website compromised via a third-party script would be a highly visible incident that damages market confidence and likely triggers regulatory scrutiny under breach notification laws.

Remediation

1. Add integrity attributes to all external script and link tags:
<script src="..." integrity="sha384-[hash]" crossorigin="anonymous"></script>
2. Implement a strict Content-Security-Policy with nonce-based script loading

3. Self-host critical JavaScript assets where possible
4. Monitor third-party CDN providers for security advisories
5. Consider using a CSP report-uri endpoint to detect policy violations

[VA-005] robots.txt Internal Path Disclosure

Low

CVSS: 2.1 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N) | Finding ID: VA-005

Description

The developer portal (developer.arkoselabs.com) exposes a robots.txt file that reveals several internal or restricted paths including: `/*api-next`, `/edit/`, `/*edit/`, `/suggested-edits/`, `/login`, and `/logout`. While robots.txt is a standard directive for well-behaved crawlers, malicious actors use it as a discovery aid for sensitive paths.

Technical Impact

Attackers can identify staging/development API endpoints (`/api-next`) and content management interfaces (`/edit/`, `/suggested-edits/`). While these paths require authentication to access, their existence is disclosed to anyone who requests robots.txt. This narrows the reconnaissance phase for targeted attacks.

Business Impact

Low direct business impact. However, revealing development and editing endpoints provides attackers with a targeted list of high-value authentication pages to attack. Reducing the information available to adversaries is a fundamental security principle.

Remediation

1. Remove internal paths from robots.txt - restrict access via authentication at the web server/application layer instead
2. Host development/staging environments on separate domains entirely
3. Use firewall rules to restrict access to `/edit/`, `/login`, and admin paths by IP range or VPN requirement
4. Return 404 (not 403/401) for unauthenticated requests to restricted paths

[VA-006] Sitemap Granular Reconnaissance Data

Low

CVSS: 1.0 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:N) | Finding ID: VA-006

Description

The sitemap.xml file at www.arkoselabs.com/sitemap.xml provides a comprehensive list of all site URLs including legal documents (MSA, DPA, SLA guarantees), sub-processor listings, global infrastructure details, patent information, and complete event/meeting schedules with locations.

Technical Impact

Information exposure that aids in social engineering and targeted reconnaissance. The patent disclosure helps competitors understand Arkose Labs' IP strategy. Event schedules reveal when and where key personnel will be present, enabling physical social engineering or targeted phishing campaigns against traveling employees.

Business Impact

While sitemaps are standard SEO tools, including detailed legal and infrastructure information provides unnecessary

reconnaissance value to competitors and adversaries. Event schedules with specific locations create opportunities for physical targeting of executives and sales personnel.

Remediation

1. Exclude legal documents, infrastructure pages, patents, and event schedules from the public sitemap
2. Consider using meta robots "noindex" tags on sensitive pages
3. Keep the sitemap focused on marketing content that benefits from SEO indexing
4. Ensure no internal-only URLs are included in the sitemap

6. Remediation Roadmap

The following roadmap prioritizes fixes by impact-to-effort ratio. Items at the top provide the greatest security improvement for the least engineering investment.

P0 - Immediate (0-2 weeks)

Action Item	Effort	Rationale
Add Strict-Transport-Security header	Low effort, high impact	Mitigates SSL-stripping MITM attacks
Add X-Frame-Options: DENY	Low effort, high impact	Prevents clickjacking attacks
Remove stale DNS records	Medium effort, high impact	Eliminates subdomain takeover risk

P1 - Short-term (2-4 weeks)

Action Item	Effort	Rationale
Implement Content-Security-Policy	Medium effort, high impact	Primary defense against XSS
Add Permissions-Policy header	Low effort, medium impact	Restricts browser API access
Implement Subresource Integrity hashes	Medium effort, medium impact	Prevents supply chain CDN attacks
Clean up verify API error responses	Low effort, low impact	Reduces information leakage

P2 - Medium-term (1-2 months)

Action Item	Effort	Rationale
Audit and trim robots.txt	Low effort, low impact	Removes path disclosure
Reduce sitemap granularity	Low effort, low impact	Limits reconnaissance data
Create DNS lifecycle policy	Medium effort, medium impact	Prevents future stale records
Subscribe to subdomain takeover monitoring	Low effort, medium impact	Proactive detection

P3 - Long-term (2-3 months)

Action Item	Effort	Rationale
Self-host critical static assets	High effort, medium impact	Reduces third-party dependency
Implement CSP reporting (report-uri)	Medium effort, low impact	Visibility into CSP violations
Quarterly DNS hygiene audits	Low effort, low impact	Ongoing maintenance

7. Appendix: Subdomain Inventory

The following subdomains were discovered during passive reconnaissance. This list should be reviewed to verify all records are intentional and properly secured.

Subdomain	Target/IP	Platform	Status
www.arkoselabs.com	104.18.30.38	Cloudflare	Active - Main website
portal.arkoselabs.com	Cloudflare-proxied	Cloudflare	Active - Customer portal
developer.arkoselabs.com	Cloudflare-proxied	Cloudflare	Active - Developer docs
client-api.arkoselabs.com	d2w650xp5tniea.cloudfr	AWS CloudFront	Active - Client API
verify.arkoselabs.com	104.18.24.64	Cloudflare	Active - Verify API
match-verify.arkoselabs.com	104.18.24.64	Cloudflare	Returns 404 - Review
cdn.arkoselabs.com	NXDOMAIN	Deprecated	Returns 404 - Review
status.arkoselabs.com	Atlassian Statuspage	Atlassian	Active - Status page
microsoft-auth.arkoselabs.co	99.86.4.15	AWS	Forbidden - Customer-speci
microsoft-api.arkoselabs.com	104.18.24.64	Cloudflare	Forbidden - Customer-speci
iframe-auth.arkoselabs.com	3.163.80.46	AWS CloudFront	Forbidden - Auth iframe
adobe-api.arkoselabs.com	Cloudflare-proxied	Cloudflare	Active - Customer-specific
prod-ireland.arkoselabs.com	34.246.164.254	AWS EC2	Active - Ireland region
uatcat-ohio.arkoselabs.com	3.130.208.198	AWS EC2	UAT environment
verify-api.arkoselabs.com	143.204.211.99	AWS CloudFront	Active - Verify API alt
tableau.arkoselabs.com	DNS only	DNS alias	DNS record exists - no res
www-staging.arkoselabs.com	DNS only	DNS alias	DNS record exists - no res
www-production.arkoselabs.co	DNS only	DNS alias	DNS record exists - no res

Note: Subdomains marked "Review" may pose takeover risk and should be investigated.

Report Summary

This vulnerability assessment was conducted as an authorized security test under the Arkose Labs Bug Bounty Program (Bugcrowd) and the Future Interns penetration testing program. All findings are based on passive and low-impact testing techniques that did not affect the availability or normal operation of the target systems.

The assessment identified 6 findings (1 High, 2 Medium, 3 Low). No critical vulnerabilities were found that would allow direct compromise of Arkose Labs infrastructure. The most impactful finding - missing security headers - can be remediated with configuration changes at the Cloudflare or origin server level requiring no code changes.

Arkose Labs maintains a strong security posture with industry-standard compliance certifications, regular penetration testing, and a mature bug bounty program. The issues identified are common across enterprise web properties and are addressed through standard security hardening practices.

Report Statistics	
Total Findings:	6
High Severity:	1
Medium Severity:	2
Low Severity:	3
Subdomains Discovered:	18
Targets Assessed:	5